

GIJO AS 보안담당자 실무 매뉴얼 — 샘플 사례로 배우는 사용법

1인 보안담당자가 매일·매주·매달 하는 일을 **화면에 심어둔 좋은 사례 6종**으로 따라 하며 익히는 실무 가이드.

이 매뉴얼의 모든 화면명·동작·자연어 지시는 **실제 제품에서 검증했습니다**(최종 갱신 2026-07-20). 화면의 샘플 이벤트는 문서용 IP(RFC 5737: 203.0.113.x·198.51.100.x·192.0.2.x)와 **샘플_** 라벨로 실제 위협과 구분됩니다.

0. 시작하기

1. **로그인**: 발급받은 계정으로 로그인합니다. 서버 연결 상태는 이상단 **● 운영중 LIVE** 로 표시됩니다 (끊기면 빨간 점). 한 계정은 **한 곳에서만** 로그인됩니다 — 다른 PC에서 로그인하면 확인 후 기존 세션이 종료됩니다(중복 로그인 방지).
2. **좌측 사이드바** = **아이콘 레일** + **서브패널**입니다. 얇은 왼쪽 띠의 **큰 아이콘(대분류)**을 누르면 바로 옆 패널에 그 분류의 화면 목록이 나오고, 항목을 클릭하면 이동합니다.
3. 가장 많이 쓰는 화면은 **관제·모니터링 > 보안 분석 (통합 관제)**입니다.

0-1. 전체 화면 지도 (실제 메뉴 구조)

사이드바는 **4대 분류 + 기능 안내 + 설정**으로 간소화되어 있습니다.

대분류(아이콘)	화면	용도
📊 관제·모니터링	대시보드 / 보안 KPI	지휘 콘솔(자연어 지시)-지표
	보안 분석 (통합 관제) ★	취약점·로그·보안제품 리포트 통합 분석
	작업 세션	진행 중 업무를 세션으로 묶어 추적
	위협 인텔리전스	CTI 피드·자산 매칭
	🔥 MCP 연동 (신규)	AI를 외부 도구·데이터(위협 인텔·스캐너·티켓·SIEM)에 연결·통제(egress 승인·에이전트별 권한·감사)
📁 자산·취약점·대응	자산 목록 / AI-BOM 구성	자산 인벤토리 + AI-BOM·AI 견고성 카드
	취약점 / 조치·승인	Nessus 분석 + 조치 결재·추적
	보안제품 / 유지보수	방화벽·백신 등 등록·매뉴얼 RAG + 점검 일정
	리포트 / 컴플라이언스	월간 리포트·규정
🤖 AI	에이전트 AI / LLM 합성 / LLM 가이드	에이전트·모델 합성·모델 안내
	기억·학습(RAG) / 문서 보강 / 온톨로지 / 학습 루프	지식·지식그래프·학습
	레드팀·가드레일	사내 AI 인젝션 방어
🔧 시스템	로그 / 작업 기록(감사)	서버 로그·전 작업 감사 타임라인
	터미널(CLI) / 원격 정기점검	담당자 PC 셸·보안장비 하드닝 자동 점검
? 기능 안내	기능 안내	전체 기능·입력칸 검색·바로가기
⚙️ 설정	설정 / 사용량·요금	설정·사용량

대시보드의 GPU 표시는 로드된 GPU 메모리(GB) 기준입니다.

0-2. 대시보드 · 공용 지휘 콘솔 (v2.3.0)

대시보드(첫 화면)는 세 부분입니다.

- **왼쪽** = 📁 **탐색기(내 PC 파일)**: 담당자 **내 문서** 폴더를 트리로 탐색. 문서 파일(pdf·hwp·txt·md 등) 클릭 → 🟡 **분석해 올리기로** 장기기억(RAG)에 바로 인입. 아래 **AS 탐색기**에 등록된 리포트·문서 목록(수량 표시). 상단 📁 로 탐색 폴더 변경.
- **가운데** = **내 업무 바로가기** + 🤖 **AI 팀**: 자주 쓰는 메뉴를 주기별(오늘/주간/월간)로 담아둔 바로가기(🔍 편집으로 담고 빼기 — **상단 툴바 아이콘도 여기 등록한 것만** 나옵니다). 아래 **AI 팀** 윗타리에 에이전트·엔진·가드레일과 🏢 **팀 사무실**(별도 창) 열기.
- **오른쪽** = 🖥️ **작업 화면**: **작업 세션**(이력)과 🗣️ **지휘 콘솔**(자연어 지시·응답). 헤더 ≡ **전체메뉴** (오른쪽 위)를 누르면 사이드바가 있는 **보안 KPI** 화면으로 이동합니다.

어느 화면에서든 AI에게 지시 — 대시보드가 아닌 다른 화면(자산·취약점·설정 등)에서는 오른쪽 가장자리  **작업 화면** 탭을 누르면 지휘 콘솔이 열립니다. 그 화면의 맥락(예: 취약점 화면에서 "정리해줘" = 우선순위 정리)이 함께 전달됩니다. *첫 지시는 모델 준비로 응답이 다소 걸릴 수 있습니다.*

접기: 오른쪽  작업 화면 의  접기 로 전체를, 각 섹션(작업 세션·지휘 콘솔) 제목의  로 개별로 여닫습니다. **보안 KPI**도 섹션 제목 클릭으로 접이식(기본 접힘, 추세 번다운만 펼침).

1. 핵심 화면 — 보안 분석 · 통합 관제 (자세히)

이 화면 하나로 세 가지 소스(취약점 스캐너 / 보안 로그 / 보안제품 운영 리포트)를 한꺼번에 봅니다.

화면 요소

- 1. **드롭존**(상단): 로그·운영 리포트 파일을 끌어다 놓으면 유형을 자동 판별해 정규화합니다. (Nessus 스캔은 취약점 화면에서 올리면 자동 반영)
- 2. **종합 위험도 타일**: 높음/보통/낮음 + P0·P1·P2 개수. P0가 있으면 종합위험 "높음".
- 3. **소스별 타일**:  취약점 /  보안 로그 /  운영 리포트 건수.
- 4. **통합 위험 우선순위 리스트**(좌): 모든 소스를 위험도순으로 병합. 소스 필터(전체/취약점/로그/운영)로 좁힐 수 있습니다.
- 5. **상세 패널**(우): 항목 클릭 시 소스·대상·상세·신호 표시.  **AI 분석** 버튼으로 "무슨 일·왜 위험·권고",  **조치 생성**으로 작업 등록.
- 6.  **상관분석 패널**(우 상단): 같은 대상이 여러 소스에 걸치면 교차 위험으로 묶어 보여줍니다.

우선순위(P0~P3) 읽는 법

등급	의미	대응
P0	즉시 조치 — 실제 악용/노출(KEV·활성악용·성공한 공격)	오늘 안에
P1	높음 — 위험 신호 있음(브루트포스·포트스캔·유출·반복)	이번 주
P2	보통 — 심각도는 있으나 활성 신호 약함	계획 대응
P3	낮음/정보	모니터링

우선순위는 **심각도 + 실제 위험 신호**로 산정합니다. "CVSS는 높지만 안 터리는 것"보다 "지금 실제로 악용되는 것"을 앞세웁니다(Tenable VPR 사상).

신호(signals) 뜻

신호	의미
KEV	CISA 악용확인 목록 등재 — 최우선
활성 악용	공격 실패 다발 후 성공 로그 존재(계정 탈취 가능)
브루트포스	인증 반복 실패
포트스캔	한 IP가 다수 목적지 포트 차단당함
웹공격	SQLi/XSS/경로순회/명령주입 흔적
유출	DLP/IDS 정보유출 정황
반복	동일 대상이 반복 등장(잔존·재발 의심)
EPSS n	30일 내 악용 확률(0~1)

2. 매일 하는 일 (Daily)

2-1. 아침 — 종합위험부터

- 1. **통합 관제**를 엽니다. 종합 위험도 타일과 **P0 개수**를 봅니다.
- 2. 우선순위 리스트는 이미 위험도순(P0→P3)이라 **위에서부터** 처리합니다.
- 3. 진행 중인 일은 **관제·모니터링 > 작업 세션**에 세션으로 묶어두면 맥락(관련 취약점·대화·조치)이 이어집니다.

2-2. 밤사이 로그 올리기 (드롭존)

- 1. 방화벽·서버·IDS 로그를 드롭존에 끌어다 놓습니다. 유형 자동 판별.

따라 하기 — 화면 샘플: 샘플_ssh브루트포스_성공사례.log 가 만든

[P0] 인증 브루트포스 의심 — 203.0.113.50 {브루트포스, 활성 악용}

클릭 →  AI 분석 →  조치 생성.

2-3. 오늘 우선순위 (자연어 지시)

- 대시보드/에이전트에게 **"오늘 제일 급한 취약점 뭐야?"** → `today` 도구로 KEV·심각도 기준 답변.
- 검증 응답 예: `*[critical] Apache Log4j RCE (CVE-2021-44228)*` (실제 CISA KEV 등재).

3. 매주 하는 일 (Weekly)

3-1. 취약점 스캔 결과 업로드

- 1. 자산·취약점·대응 > 취약점 화면 → Nessus `.nessus` (원본 XML)·CSV·HTML 업로드.
- 2. 호스트별 자산 등록 + 플러그인 중복제거 + **EPSS·VPR·CISA KEV** 자동 인식.

3. 지난 스캔 대비 상태 표기:
4.  신규 /  재발 /  고쳐짐(검증됨) /  고쳐짐(미검증)
5. "미검증"은 비인증(원격) 스캔에서 사라진 것 → 인증(credentialed) 재스캔으로 재확인 필요.
6. 조치는 자산·취약점·대응 > 조치·승인 탭에서 결재·추적합니다.

3-2. 보안제품 운영 리포트 검토

백신·EDR·DLP·IDS 주간 리포트를 드롭존에 올립니다. 키워드(유출/차단/격리/탐지)와 반복 대상을 자동 집계.

따라 하기 — 화면 샘플 3종

- 샘플_DLP_개인정보유출차단사례.csv → [P1] 유출 — 반복 사용자 소명
- 샘플_백신_악성코드격리사례.csv → [P1] 반복 탐지 — PC-SAMPLE {반복} — 동일 단말 재발=잔존 감염 → 정밀검사
- 샘플_IDS_정보유출경보사례.log → [P1] 유출 + 반복 탐지 192.0.2.77 — 아웃바운드 조사

3-3. 조치·SLA 점검

- SLA 임박·초과 알림 확인, 지연 건 담당·기한 조정.

4. 매달 하는 일 (Monthly)

- 종합 리포트: 자산·취약점·대응 > 리포트에서 월간 리포트(Word/PDF) 생성.
- 보안제품 매뉴얼 최신화: 자산·취약점·대응 > 보안제품 → 제품에 최신 운영 매뉴얼(PDF/HWPX/TXT) 첨부 → 텍스트 추출 → 지식베이스(RAG) 수집. 이후 매뉴얼 근거로 답변.

> 검증: RAG에 "방화벽 운영 매뉴얼" 질의 → 실제 문서 내용(정책 관리·백업 매주 금요일·펌웨어 업데이트) 반환.

- 보안장비 하드닝 점검: 등록된 장비의 원격 정기점검 준수율 추세를 확인하고, 악화된 장비를 조치합니다(6장).
- AI 견고성 점검(5장).

5. AI 보안 (특별 — 사내 AI가 늘수록 필수)

5-1. 레드팀 — 우리 AI가 인젝션에 안전한가

1. AI > 레드팀·가드레일 화면 → 상단 점검 대상 드롭다운에서 선택:
2. 오케스트레이터(메인 LLM) / 로컬 모델 / AI-BOM 자산
3. ※ AI-BOM 자산은 그 자산에 연결 로컬 모델(modelRef)을 지정했을 때만 목록에 나타납니다.
4. ▶ 레드팀 실행 → 14개 인젝션/탈옥 공격으로 견고성 점수(0~100) 실측(약 1분).
5. 뚫린 항목 클릭 → 공격·모델응답·판정근거·권고 확인. AI-BOM 자산이면 점수가 그 자산에 기록됩니다.

5-2. 가드레일 — 실시간 방어

모드	동작
끔	검사 안 함
탐지	인젝션 감지 시 기록만(진행 허용) — 기본
차단	인젝션 의심 요청 거절 — 운영 권장

검증: 실제 공개 탈옥 프롬프트 8개 → 차단 모드에서 8/8 차단. 원본 모델이 취약해도 가드레일 차단 모드가 방어선입니다.

6. 보안장비 점검 — 터미널(CLI)·하드닝·원격 정기점검 (신규)

방화벽·리눅스 서버 같은 보안장비의 보안 설정(하드닝)이 기준(국내 CCE / CIS)에 맞는지 점검하고, 정기적으로 자동 점검합니다.

6-1. 터미널(CLI) — 담당자 PC에서 직접 명령

- 1. 시스템 > 터미널(CLI) 화면은 담당자 본인 PC의 셸(PowerShell)을 앱 안에서 직접 실행합니다(서버가 아닙니다).
- 2. 위험 명령(드라이브 삭제·포맷·시스템 종료 등)은 실행 전 자동 차단됩니다.
- 3. 챗봇에게 명령 요청: "10.0.0.5 포트 스캔해줘" → 챗봇이 명령을 제안만 하고, 허용목록·위험 판정 → 사람 승인 후에만 실행됩니다.
- 4. 모든 실행·차단·승인은 작업 기록(감사)에 남습니다.

6-2. 하드닝 점검 — 챗봇 명령으로 즉시 점검

- 터미널 화면의 빠른 점검 칩(🇰🇷 국내 CCE / 🌐 CIS)을 누르거나, 챗봇/지휘 콘솔에 "이 장비 하드닝 점검해줘"라고 하면 대상 장비 CLI에서 표준 점검 명령을 실제 실행해 리포트를 만듭니다.
- 점검 기준 2종:
 - 국내 CCE (KISA 주요정보통신기반시설 취약점 분석·평가, U-시리즈) — 계정 정책·파일 권한·로그 등 11항목
 - CIS Benchmark (Level 1) — 방화벽·SSH·NTP·서비스 최소화 등 7항목
- 리포트는 분류별(계정 관리·파일·디렉터리·로그 관리)로 그룹핑되어 그룹마다 양호/취약 소계와 조치 권고를 보여줍니다.

> 검증: 점검 결과 예 — 준수율 50%, PASS_MAX_DAYS=99999 (패스워드 최대 사용기간) 취약 → 90일 이하로 설정 권고.

6-3. 원격 정기점검 관제 — SSH로 자동 점검

- 1. 시스템 > 원격 정기점검 화면에서 + 대상 등록 → 장비 이름·호스트·포트·계정·인증(SSH 키 권장 / 비밀번호 / 로컬) 입력 → 등록 시 접속 확인까지 자동.
- 2. 카드의 스케줄에서 점검 기준(CCE/CIS)과 주기(예: 24시간)를 정하면, 서버가 그 주기마다 원격 접속해 자동 점검합니다.

3. **관제 화면**은 한눈에 보여줍니다:

4. 상단 KPI — 등록 장비·활성 스케줄·**평균 준수율·악화 경고** 수

5. 장비 카드 — 현재 준수율 + **준수율 추세(그래프)** + 다음 점검 시각, 지난 점검보다 나빠지면 ▼ **악화 경고**

6. **정기점검 켜기/끄기 토글**, **지금 점검**, **삭제**를 카드에서 바로 할 수 있습니다.

> 검증: 스케줄 등록 → 서버 스케줄러가 자동 실행(CIS 준수율 67%, "정기" 이력 기록). 모든 점검은 감사 로그에 남습니다.

쉽게: 장비를 한 번 등록해두면 서버가 정한 주기마다 스스로 SSH로 접속해 "보안 설정이 기준에 맞는지" 점검하고 점수를 쌓아둡니다. 점점 나빠지면 빨간 경고가 뜹니다.

7. 작업 기록 (감사 로그)

시스템 > **작업 기록(감사)** 화면은 "누가·언제·무엇을 실행/승인/차단/변경했나"를 **하나의 타임라인**으로 남깁니다.

- 기록 종류: CLI 실행·차단 / 결재판 승인 / 쓰기 작업 / 로그인 / 하드닝 점검 / 설정 변경.
- 끝 수 없습니다**(감사 무결성). 종류 필터·검색·CSV 내보내기 지원, 15초마다 갱신.
- 사건 조사·내부 감사·컴플라이언스 증적으로 씁니다.

8. 자연어 지시 (검증된 도구 매핑)

대시보드/에이전트 화면에서 아래처럼 지시하면 해당 도구가 실행됩니다(모두 실제 검증).

지시	실행 도구	결과
"오늘 제일 급한 취약점 뭐야?"	today	KEV·심각도 최우선 취약점
"제일 위험한 취약점 3개 알려줘"	today	상위 3개
"web01 Log4j 조치 절차 알려줘"	remediation	패치·완화 절차(매뉴얼 RAG+온톨로지)
"이 장비 하드닝 점검해줘" / "CCE 점검"	run_hardening_scan	CCE/CIS 기준 하드닝 점검 리포트
"web01 Log4j 담당 정요한으로 배정해줘"	assign_finding	결재판 (값 확인·승인 후 실행)

9. 결재판 — 쓰기 작업 승인 (안전장치)

담당 배정·상태 변경 같은 **쓰기 작업**은 바로 실행되지 않고 **결재판**으로 뜹니다.

- AI가 채운 값(대상 자산·취약점·담당·기한 등)을 **확인·수정**합니다.
- 승인**을 누를 때만 DB에 반영됩니다.
- 실수 시 **원클릭 되돌리기(undo)**로 방금 승인을 통째로 취소할 수 있습니다.

검증: "담당 정요한 배정" → *"아래 값을 확인하고 승인해 주세요"* 결재판 표시.

10. 사례별 대응 요약 (화면 샘플 = 교재)

샘플 이벤트	우선순 위	무슨 일	즉시 조치
인증 브루트포스 — 203.0.113.50	P0	실패 다발 후 성공=계정 탈취 가 능	IP 차단 + 계정 비번 재설정·세션 종 료
포트 스캔 — 198.51.100.20	P1	다수 포트 차단=정찰	스캐너 IP 차단, 노출 서비스 점검
웹 공격 — 192.0.2.30	P2	SQLi/XSS/경로순회	WAF 룰, URL 로그 정밀분석
DLP 유출 차단	P1	개인정보 유출 시도	반복 사용자 소명, 정책 강화
백신 격리 반복 — PC-SAMPLE	P1	동일 단말 재발=잔존 감염	단말 격리·정밀검사
IDS 정보유출 — 192.0.2.77	P1	반복 아웃바운드 유출 정황	프로세스·목적지 조사·차단

상관분석 팁: 같은 대상(IP/PC)이 여러 소스에 걸치면 🔗 상관분석에 묶입니다 — 예) 백신 재발 PC + 비정상 아웃바운드가 같은 단말이면 "감염+유출 연계"로 함께 조사.

11. 용어 설명

- **KEV:** CISA Known Exploited Vulnerabilities — 실제 악용이 확인된 취약점 목록. 등재 시 최우선.
- **EPSS:** 향후 30일 내 악용 확률(0~1). **VPR:** Tenable 위험 기반 우선순위 점수(0~10).
- **RAG:** 문서를 벡터로 저장해 질문에 근거 문장을 찾아주는 검색·증강. 매뉴얼이 곧 검색 가능한 지
식.
- **온톨로지:** 표준·개념 간 명시적 관계(그래프). 답변 근거로 함께 주입.
- **AI-BOM:** AI 자재명세 — 모델·데이터·프롬프트·도구·인프라 5영역 구성명세.
- **레드팀 / 가드레일:** 레드팀은 공격 프롬프트로 AI 견고성을 실측하는 사후 점검, 가드레일은 실시간
입력을 검사해 프롬프트 인젝션을 탐지·차단하는 방어.
- **하드닝(Hardening):** 장비의 보안 설정을 기준에 맞게 잠그는 것(불필요 서비스 차단·계정 정책·권
한 등).
- **CCE (KISA U-시리즈):** 「주요정보통신기반시설 기술적 취약점 분석·평가」 기준. 국내 공공·금융 점
검의 사실상 표준.
- **CIS Benchmark:** 국제 하드닝 기준(계정·방화벽·SSH·로깅 등).
- **SSH:** 원격 장비에 안전하게 접속·명령을 보내는 표준 통로. 키 인증을 권장합니다.
- **감사 로그:** 모든 실행·승인·차단·변경을 남기는 끌 수 없는 작업 타임라인.

12. FAQ / 문제 해결

- **Q. 레드팀/AI 분석/하드닝 점검이 느려요.** 로컬 LLM이 처음 로드될 때 시간이 걸립니다(수십 초).
이후엔 빨라집니다.
- **Q. "서버 연결 끊김"이 떠요.** 서버가 내려갔을 수 있습니다. 서버 프로세스를 재시작하세요.

- **Q. 원격 정기점검에서 접속이 안 돼요.** 대상의 호스트·포트·계정과 **SSH 키 경로**를 확인하세요(키 인증 권장). 등록 시 "접속 확인"이 실패로 나오면 방화벽·자격증명 문제입니다.
- **Q. 하드닝 점검 결과가 다 취약이에요.** 실제 장비 설정이 기준 미달일 수 있습니다 — 리포트의 조치 권고대로 설정을 고친 뒤 다시 점검하면 준수율이 올라갑니다.
- ****Q. 화면의 샘플_* 이벤트를 지우고 싶어요.**** 학습용 예시(문서용 IP)입니다. 실데이터를 올리면 함께 정렬되며, 필요 없으면 무시하거나 관리자에게 정리를 요청하세요.
- **Q. 조치가 바로 반영 안 돼요.** 쓰기 작업은 결재판 승인 후에만 반영됩니다(9장).
- **Q. AI-BOM 자산이 레드팀 대상에 안 보여요.** 해당 자산의 AI-BOM에서 **연결 로컬 모델**을 먼저 지정해야 합니다.
- **Q. 챗봇이 위험한 명령을 실행하면 어찌죠?** 터미널의 위험 명령은 항상 차단되고, 챗봇 제안은 **사람 승인 후에만** 실행됩니다. 모든 실행은 작업 기록에 남습니다.

화면의 샘플_ 이벤트는 학습용 예시입니다(문서용 IP). 실제 운영 시 여러분 환경의 로그·리포트·스캔을 올리면 동일하게 분석됩니다. 본 매뉴얼은 실제 제품 동작을 검증해 작성했습니다(최종 갱신 2026-07-20).*